CLOUDSHIELD TECHNOLOGIES

Privileged Access & MFA

Control Assessment Report

GRC-002: Incomplete MFA Enforcement for Privileged Accounts

Independent GRC Portfolio Project: Simulated Organization

Assessment ID	IAM-CTL-002
Control Area	Identity & Access Management / Privileged Access
Systems	Microsoft Azure / Production Environment
Inherent Risk	High: 16/25
Overall Test Result	FAIL: Remediation Required
Risk Treatment	Mitigate
Linked Policy	CloudShield Access Control & Identity Management Policy
Retest Required	Yes

1. Executive Summary

CloudShield assessed privileged authentication and access controls after identifying two privileged identities outside the standard MFA requirement. The sample included one interactive human administrator account and one non-human deployment service account. Neither exception had documented approval, compensating controls, or a defined review/expiration record.

Overall result: FAIL; REMEDIATION REQUIRED. The control objective is not operating effectively because privileged access is not consistently protected according to identity type and exception governance is absent.

2. Control Objective

Ensure privileged identities use authentication and access protections appropriate to their identity type, that privileges are limited to business need, and that any exception to the standard control is documented, approved, time-limited, monitored, and periodically reviewed.

3. Why Identity Type Matters

Identity Type	Control Approach
Interactive human administrator	A person signs in and can respond to authentication challenges. MFA is required for eligible privileged interactive access.
Non-human workload / service identity	An automated process cannot reliably respond to an interactive MFA prompt. The security objective should instead be achieved through managed/workload identity where feasible, least privilege, secure credential handling, restricted use, logging, and monitoring.
GRC principle	The control objective remains strong authentication and controlled privileged access, but the technical implementation may differ based on how the identity is used.

4. Evidence Requested / Reviewed

- Privileged-account inventory and Azure role assignments.
- MFA registration / authentication-method evidence for interactive administrators.
- Conditional Access or equivalent enforcement configuration and exclusion list.
- Service-account / workload-identity inventory and authentication method.
- Credential or secret age, storage method, and rotation evidence where applicable.
- Business justification and approval for privileged-authentication exceptions.
- Sign-in / activity logs for sampled privileged identities.
- Evidence of periodic privileged-access review.

5. Test Procedure

1. Select the identified privileged identities and classify each as human interactive or non-human workload/service identity.

2. Confirm the privileges assigned and whether they are necessary for the stated business purpose.

3. For human privileged access, verify MFA enrollment and technical enforcement; inspect exclusions.

4. For non-human access, determine whether interactive MFA is technically appropriate and inspect the authentication design.

5. Review long-lived credentials/secrets, permission scope, use restrictions, and monitoring.

6. Inspect any exception record for business justification, compensating controls, approver, expiration, and review date.

7. Document design and operating-effectiveness results and define remediation/retest criteria.

6. Sample Results

Identity	Type	Observed Condition	Control Expectation	Result	Risk
azure-admin-legacy	Human privileged administrator	Production privileges; excluded from MFA because	Require MFA for interactive admin access and separate	FAIL	High

Identity	Type	Observed Condition	Control Expectation	Result	Risk
		an older automation workflow sometimes uses the account.	automation from the person's privileged identity.		
svc-deployment-prod	Non-human deployment service account	Long-lived secret; broad production permissions; no formal exception or documented compensating-control package.	Use appropriate workload/managed identity where feasible; least privilege; remove/rotate old secret; restrict and monitor use.	FAIL	High

7. Findings

Finding ID	Finding	Severity	Assessment
IAM-F01	Interactive privileged account excluded from MFA	High	A human administrator retains production privilege without MFA enforcement. Automation is improperly coupled to the person's interactive privileged identity.

Finding ID	Finding	Severity	Assessment
IAM-F02	Service identity uses long-lived broadly privileged secret	High	The deployment identity relies on a long-lived secret and broad permissions rather than a stronger workload-identity design and least privilege.
IAM-F03	Privileged authentication exceptions are not governed	High	No formal record documents justification, compensating controls, approval, expiration, or periodic review for either exception.

8. Corrective Action Plan

Action	Corrective Action	Owner	Target	Status
IAM-CAR-01	Remove the human administrator's MFA exclusion and verify MFA enforcement for privileged interactive access.	IAM / Security	Immediate / highest priority	Open
IAM-CAR-02	Separate the legacy automation from azure-admin-	Cloud / Engineering	30 days	Open

Action	Corrective Action	Owner	Target	Status
	legacy so automation does not depend on a person's privileged interactive identity.			
IAM-CAR-03	Migrate svc-deployment-prod to a managed/workload identity or other approved non-interactive authentication design where feasible.	Cloud / IAM	30 days	Open
IAM-CAR-04	Apply least privilege to the deployment identity; restrict where/how it can authenticate; enable appropriate activity monitoring.	Cloud / Security	30 days	Open
IAM-CAR-05	Rotate and revoke the old long-lived deployment secret	Cloud / IAM	At migration completion	Open

Action	Corrective Action	Owner	Target	Status
	after migration and preserve evidence of revocation.			
IAM-CAR-06	Implement a formal privileged-access exception process with owner, justification, compensating controls, approval, expiration, and periodic review.	Security / GRC	30 days	Open

9. Exception Governance Requirements

An exception may be appropriate when a standard control cannot technically or operationally be implemented immediately. An exception must not become a permanent undocumented bypass.

Required Element	Requirement
Business / technical justification	Explain why the standard control cannot currently be applied.
Identity and privilege scope	Identify the account, systems, permissions, and business process affected.
Compensating controls	Document alternative safeguards such as restrictions, monitoring, credential controls, or segmentation.
Risk owner	Identify the person/function accountable for the residual risk.

Required Element	Requirement
Approval	Obtain approval appropriate to the level of privilege and risk.
Expiration / review	Set a defined expiration date and periodic review; renew only with documented justification.
Remediation plan	State how and when the exception will be eliminated or reduced.

10. Design vs. Operating Effectiveness

Assessment Area	Conclusion
Control Design	Needs Improvement — the intended MFA/privileged-access requirement exists, but identity-type handling and exception governance need clearer formalization.
Operating Effectiveness	Ineffective — sampled privileged identities are outside expected protections and no approved exception evidence was available.
Overall Test Result	FAIL — remediation and retesting are required.
Residual Risk	Remain High while remediation is outstanding; do not reduce risk merely because corrective actions have been planned.

11. Retest Criteria

- Verify azure-admin-legacy is protected by MFA for interactive privileged authentication.
- Verify legacy automation no longer depends on the human administrator's interactive privileged identity.
- Verify svc-deployment-prod uses the approved non-human authentication design.
- Verify the old long-lived secret is rotated/revoked as appropriate and no longer used.
- Verify deployment privileges are reduced to least privilege and use restrictions are operating.

- Inspect logs/monitoring evidence for privileged activity.
- Verify any remaining exception has documented justification, owner, compensating controls, approval, expiration, and review.
- Perform and retain a documented privileged-access review.

12. Final Assessment

GRC-002 remains High until the corrective actions are implemented and tested. CloudShield should require MFA for the interactive human administrator while redesigning the non-human deployment identity around secure workload authentication, least privilege, credential reduction, restricted use, and monitoring. This approach preserves the security objective without applying an unsuitable interactive control to an automated process.

Appendix A: Privileged Identity Review Record

Review Field	Recorded Result
Assessment ID	IAM-CTL-002
Human Identity	azure-admin-legacy
Human MFA Result	Fail: excluded from MFA
Service Identity	svc-deployment-prod
Service Authentication Result	Fail: long-lived secret / broad privilege
Exception Evidence	Not available
Overall Result	Fail: remediation required
Risk	High: 16/25
Treatment	Mitigate
Retest	Required